MCP 设备审计报告

日期：2026-10-24

审计器：CBAP `MCPDeviceDriver` + `mcp_device_probe.py`

被测对象：本机可运行的 MCP server；不含手机端未导出的 server

结论性质：行为/语义审计，不是安全认证，也不是对开发者动机的判断

---

0. 执行摘要

这次没有把“返回 ok 但没做到”直接定性成造假。

更准确的结论是：

```
MCP tool receipt  ≠  independent device fact
```

CBAP 侧新增了通用 MCP 设备驱动和事实探针，能够把一次动作分成：

```
verified       工具确实做了，独立事实也能读到
mismatch       工具说做了，但事实不匹配
unverifiable   没有事实源，无法证明
```

本机实测结果：

```
撤谎演示灯：tool_ok=true，status=mismatch
真实 mineflayer-mcp move：事实稳定后 verified
真实 mineflayer-mcp dig：目标方块消失，verified
mineflayer-mcp chat：只能读到本地 outgoing buffer，unverifiable
mineflayer-mcp：9 个工具中没有真正的 stop/estop
server-memory 2.0.0：未复现悬空关系；失败会明确拒绝
```

没有发现可明确称为“安全漏洞”的 RCE / 认证绕过。

发现的是能力缺口、回执缺口和事实传播延迟。

如果另有具体漏洞，需要 server、版本、请求报文和实际结果才能确认。

---

1. 范围与环境

实际运行

```
OS            Linux x86_64
Node          v22.23.3
MCP server    external/mineflayer-mcp
MCP 版本      package.json 0.3.0 / serverInfo 0.2.0
Minecraft     1.21.1 测试服
CBAP          Python 3.14 + Kernel
测试套件      66/66 passed
```

实际审计的 server

```
mineflayer-mcp
@modelcontextprotocol/server-memory 2.0.0
本地 fake MCP hardware（诚实灯 / 撒谎灯 / 温度计）
```

未能审计

```
server-filesystem   npm registry 超时，未安装
jsdom browser       只在手机端，未导出
Chromium            未安装
```

---

2. 方法

2.1 不信任 tool 回执

MCP 的 `tools/call` 返回 `{content, isError}`。

很多工具会返回：

```
{"ok": true}
```

但 CBAP 不把它当完成，而是执行：

```
tool call
  → 等 facts 稳定
  → 从独立 tool/resource 读状态
  → 与 expectation 比较
```

2.2 三种结果

```
verified       工具成功，事实匹配
mismatch       工具成功，事实不匹配
unverifiable   没有事实源；拒绝当成功
```

2.3 事实稳定窗口

设备事实可能比 tool 回执晚：

```
Minecraft server tick
MQTT broker round trip
HTTP device polling
```

`MCPDeviceDriver` 使用：

```
facts_timeout_ms
poll_interval
tolerance
```

示例：

```
{
  "facts_timeout_ms": 2000,
  "poll_interval": 0.2
}
```

---

3. 实测结果

3.1 mineflayer-mcp 的 `move`

起点：

```
{"x": 21.5, "y": 66, "z": -45.5}
```

调用相对移动 `dx=4`：

```
{"reached": true,
 "position": {"x": 29.501, "y": 66.922, "z": -45.431}}
```

动作后立即读 facts：仍是旧坐标。

等服务器 tick 后：

```
{"x": 29.5008, "y": 66, "z": -45.43}
```

CBAP 判：

```
verified（带数值容差）
```

这条说明的是：

```
工具确实移动了
tool 返回的坐标是动作瞬间值，不是最终设备事实
```

不是造假。

3.2 mineflayer-mcp 的 `dig`

目标：`dirt` at `(30, 65, -47)`。

工具返回：

```
{"ok": true, "dug": "dirt",
 "position": {"x": 30, "y": 65, "z": -47}}
```

随后用 `observe target=blocks` 重读，目标方块已消失：

```
verified
```

3.3 mineflayer-mcp 的 `chat`

工具返回：

```
{"ok": true, "sent": "cbap-audit-..."}
```

`observe target=chat` 能读到这条消息，但它是 server 的**本地 outgoing buffer**，不是 Minecraft 服务端回声。

```
status = unverifiable
```

它最多证明：

```
MCP server 认为它调用了 bot.chat()
```

不能证明：

```
服务端真的收到并广播了这条聊天
```

3.4 mineflayer-mcp 的 stop 能力

工具列表：

```
observe
move
chat
dig
```

```
place
attack
use
inventory
status
```

没有：

```
stop
estop
halt
cancel
```

`chat("stop")` 不是急停，只是聊天。

因此 CBAP 对它的安全能力只能标记：

```
estop = unavailable
```

这是本轮最重要的能力缺口。

3.5 server-memory 2.0.0

实测序列：

```
create A
create relation A -> GHOST
delete A
delete A again
read_graph
```

结果：

```
create A                        -> ok
create relation A -> GHOST      -> rejected: Entity GHOST not found
delete A                        -> "Entities deleted successfully"
delete A again                  -> "Deleted 0 of 1 entities. Not found: A"
read_graph                      -> A 确实不存在
```

结论：

```
2.0.0 没有复现手机交接件里的悬空关系
删除的“0 of 1”也明确写出来了
```

这不是“假成功”；是较新的版本已经把语义补上了。

3.6 撒谎灯演示

同一个协议、同一个驱动，只把 MCP server 换成撒谎实现：

```
turn_on 工具返回：ok:true
get_state 事实：on=false
```

CBAP 结果：

```
tool_ok = true
status = mismatch
actual.on = false
```

这就是“回执 vs 事实”的最小可复现实验。

---

4. 发现清单

ID	发现	严重度	性质
M-01	`mineflayer-mcp` 没有真正的 stop/estop	高	能力/安全
M-02	`chat/use/drop` 等只有自报成功，缺少独立后置事实	中	语义

ID	发现	严重度	性质
M-03	设备事实可能晚于 tool 回执（`move` 实测）	中	一致性
M-04	`observe chat` 只读本地 outgoing buffer	中	可观测性
M-05	package 0.3.0 / serverInfo 0.2.0 版本不一致	低	元数据
M-06	未审计 filesystem/browser	—	范围限制

M-01 说明

这是“不能安全地远程控制”的问题，不是“MCP 协议本身有漏洞”。

建议修复：

```
增加 stop / estop / halt 工具
或明确声明本 server 不支持远程急停
```

在这之前，CBAP 应当拒绝把 `mineflayer-mcp` 标成可急停设备。

M-02 说明

建议为动作增加独立后置事实：

```
chat    -> server echo / chat resource
use     -> inventory / effect observation
drop    -> inventory count before/after
dig     -> block state after
```

CBAP 只能基于这些事实验收，不能基于 `ok`。

M-03 说明

不是 bug 本身，而是验收器必须处理：

```
tool return
  → settle window
  → facts read
```

一次读取就判 mismatch，会制造假阳性。

M-05 说明

`package.json` 是 0.3.0，MCP `serverInfo.version` 是 0.2.0。

不影响动作，但会影响版本追溯和 issue 复现，建议统一。

---

5. 可提交 issue 的草稿

Issue A：缺少 stop/estop

Title：`mineflayer-mcp exposes no stop/estop primitive; chat is not a safety stop`

Environment：

```
mineflayer-mcp package 0.3.0
serverInfo 0.2.0
Minecraft 1.21.1
MCP stdio
```

Observed：

```
tools/list returns 9 tools, none is stop/estop/halt/cancel.
chat can send text but cannot stop pathfinder or pending actions.
```

Expected：

A real stop/estop tool that cancels pathfinding and in-flight actions,
and a verifiable safe state.

Impact:

A supervisor cannot enforce emergency stop on the body.

Issue B：动作回执缺少事实

Title: Some mineflayer-mcp actions return success without a postcondition fact

Observed:

chat/use/drop return self-reported success.

Expected:

Return or expose an independent postcondition (inventory, block, chat echo).

Issue C：版本元数据不一致

Title: serverInfo.version (0.2.0) differs from package version (0.3.0)

Expected:

serverInfo.version matches package.json or is documented as protocol version.

---

6. 复现

6.1 CBAP 全套

```
python3 tools/cbap_conformance.py --target fake
```

结果：

66/66 passed

6.2 单个 MCP 设备

```
python3 tools/mcp_device_probe.py drivers/mcp_device/examples/light.json \
  --op turn_on --expect '{"on":true}'
```

输出：

```
{"ok": true, "status": "verified", "actual": {"on": true}}
```

撒谎灯：

```
python3 tools/mcp_device_probe.py drivers/mcp_device/examples/light-liar.json \
  --op turn_on --expect '{"on":true}'
```

输出：

```
{"ok": false, "status": "mismatch", "actual": {"on": false}}
```

推入 Kernel：

```
open -> lease -> write(channel=mcp, expect=...)
-> read(channel=state)
```

测试：

```
tests/cbap/test_mcp_device.py
```

6.3 真实 mineflayer-mcp

```
external/mineflayer-mcp/src/index.js
  --host 127.0.0.1 --port 25565
  --username AuditBot --version 1.21.1
```

CBAP manifest 使用：

```
"facts": {"source": "tool", "tool": "observe",
          "args": {"target": "position"}},
"facts_timeout_ms": 2000
```

---

7. 判定边界

本报告**不**声称：

```
mineflayer-mcp 故意造假
server-memory 一定安全
第三方 MCP 没有其他漏洞
```

本报告**可以**声称：

```
CBAP 能在动作后用独立事实区分 verified / mismatch / unverifiable
mineflayer-mcp 当前没有真正的 stop/estop
mineflayer-mcp 的 chat 事实只是本地 buffer
mineflayer-mcp 的 move 事实存在传播延迟
server-memory 2.0.0 对 GHOST 关系会明确拒绝
```

如果主人手上的漏洞与以上不同，请补充：

```
server / 版本
请求/响应原文
实际设备状态
复现命令
```

我会把它补成一条 CBAP 回归，而不是先写结论。

---

8. 产物

```
drivers/mcp_device/driver.py
tools/mcp_device_probe.py
tests/cbap/test_mcp_device.py
tests/cbap/fake_mcp_hardware.py
docs/MCP-device-audit-2026-10-24.md
```

提交：

```
6f4a8bc  CBAP: add generic MCP device driver and fact audit
```

```
1b94d25  CBAP: integrate generic MCP devices and audit real servers
```